

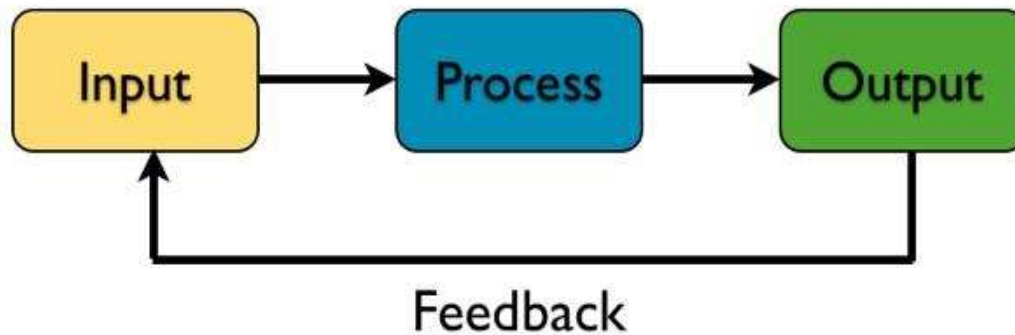
Unit 1

Introduction to Information Security and IS Auditing

• Information Systems

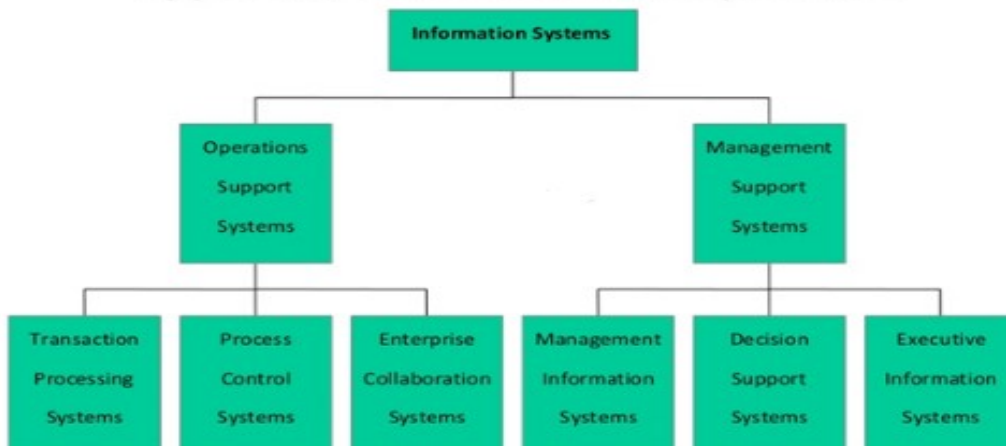
An information system (IS) is typically considered to be a set of interrelated elements or components that collect (input), manipulate (processes), and disseminate (output) data and information and provide a feedback mechanism to meet an objective.

It is a set of interrelated components working together to collect, retrieve, process, store, and distribute information for the purpose of facilitating planning, control, coordination, analysis, and decision making in business organizations.



Types of Information System Information System has following types –

Types of Information Systems



1. Operations support systems process data generated by business operations Major categories are:

- Transaction processing systems
- Process control systems
- Office automation systems

2. Management Support Systems provide information and support needed for effective decision making by managers Major categories are

- Management Information System
- Decision Support Systems
- Executive Information System

1. Operations Support System

i) Transaction processing systems

- It processes business exchanges
- Maintain records about the exchanges
- Handle routine, yet critical, tasks
- Perform simple calculations

ii) Process control systems monitor and control industrial processes.

iii) Office automation systems automate office procedures and enhance office communications and productivity.

2. Management support systems provide information and support needed for effective decision making by managers Major categories are:

i) **Management information systems**

- Routine information for routine decisions
- Operational efficiency
- Use transaction data as main input
- Databases integrate MIS in different functional areas

ii) **Decision Support System**

- Interactive support for non-routine decisions or problems
- End-users are more involved in creating a DSS than an MIS

iii) **Executive information systems**

It provide critical information tailored to the information needs of executives Other categories:

- a) Expert systems Expert Systems are knowledge-based systems that provides expert advice and act as expert consultants to the users
- b) End user computing systems End user computing systems support the direct, hands on use of computers by end users for operational and managerial applications
- c) Business information systems Business information systems support the operational and managerial applications of the basic business functions of a firm.
- d) Strategic information systems Strategic information systems provide a firm which strategic products, services, and capabilities for competitive advantage
- e) Enterprise Resource Planning (ERP) ERP is an integrated program that can manage a company's entire set of business operations. It often coordinates planning, inventory control, production and ordering

● **Components of an Information System**

An information system can be any organized combination of the components such as people, hardware, software, communications network, and data resources that collects, transforms, and disseminates information in an organization.

Information Security

Definition: Security: It is the quality or state of being secure to be free from danger. Security is achieved using several strategies simultaneously.

Specialized areas of Security:

- Physical security
- Personal security
- Operations security
- Communications security
- Network security
- Information Security (Info Sec)
- Computer Security



CIA Triangle The C.I.A. triangle is made up of

- Confidentiality,
- Integrity
- Availability

Confidentiality – Confidentiality of information ensures that only those with sufficient privileges may access certain information

- To protect confidentiality of information, a number of measures may be used including:
 - Information classification
 - Secure document storage
 - Application of general security policies
 - Education of information custodians and end users

Integrity – Integrity is the quality or state of being whole, complete, and uncorrupted

- The integrity of information is threatened when it is exposed to corruption, damage, destruction, or other disruption of its authentic state
- Corruption can occur while information is being compiled, stored, or transmitted

Availability – Availability is making information accessible to user access without interference or obstruction in the required format

- A user in this definition may be either a person or another computer system
- Availability means availability to authorized users

Privacy –

- Information is to be used only for purposes known to the data owner This does not focus on freedom from observation, but rather that information will be used only in ways known to the owner

Identification – Information systems possess the characteristic of identification when they are able to recognize individual users

- Identification and authentication are essential to establishing the level of access or authorization that an individual is granted

Authentication -

Authentication occurs when a control provides proof that a user possesses the identity that he or she claims

Authorization –

After the identity of a user is authenticated, a process called authorization provides assurance that the user (whether a person or a computer) has been specifically and explicitly authorized by the proper authority to access, update, or delete the contents of an information asset

Accountability–

The characteristic of accountability exists when a control provides assurance that every activity undertaken can be attributed to a named person or automated process

Principles of Information Security Management

- Information security management is part of the organizational management team.
- The extended characteristics of information security are known as the six
 - Planning,
 - Policy,
 - Programs,
 - Protection,
 - People,
 - Project Management

Planning: Information Security planning are activities necessary to support the design, creation, and implementation of information security strategies as they exist within the IT planning environment.

- Several types of Information Security plans exist:
 - Incident response
 - Business continuity

- Disaster recovery
- Policy
- Personnel
- Technology rollout
- Risk management and Security program
- including education, training and awareness

Policy: Policy is a set of organizational guidelines that dictates certain behavior within the organization In Information Security; there are three general categories of policy:

- General program policy (Enterprise Security Policy)
- An issue-specific security policy (ISSP)
- System-specific policies (SSSPs)

Programs: specific entities managed in the information security domain

- A security education training and awareness (SETA) program is one such entity
- Other programs that may emerge include a physical security program, complete with fire, physical access, gates, guards, and so on

Protection: Risk management activities, including risk assessment and control, as well as protection mechanisms, technologies, and tools

- Each of these mechanisms represents some aspect of the management of specific controls in the overall information security plan

People- People are the most critical link in the information security program

- It is imperative that managers continuously recognize the crucial role that people play
- Including information security personnel and the security of personnel, as well as aspects of the SETA program

Project Management:

- Project management discipline should be present throughout all elements of the information security program
- It Involves Identifying and controlling the resources applied to the project

Measuring progress and adjusting the process as progress is made toward the goal

● **Components of Information Security**

Confidentiality, Integrity, Availability, Authenticity, Non-repudiation,

Information security analysts Controls - Controlling Information Systems

Information technology controls (or IT controls) are specific activities performed by persons or systems designed to ensure that business objectives are met.

IT control objectives relate to the confidentiality, integrity, and availability of data and the overall management of the IT function of the business enterprise.

- Controls: Controls are methods, policies, and procedures. These ensures protection of organization's assets as well as accuracy and reliability of records, and operational adherence to management standards.
- General controls

ITGC include controls over the Information Technology (IT) environment, computer operations, access to programs and data, program development and program changes.

- Application controls

IT application controls refer to transaction processing controls or "input-processing-output" controls. For specific application.

Hardware controls

- Physically secure hardware
- Monitor for and fix malfunction
- Environmental systems and protection
- Backup of disk-based data

Software controls

- Authorised access to systems

Computer operations controls

- Day-to-day operations of Information Systems
- Procedures
- System set-up

- Job processing
- Backup and recovery procedures

Implementation controls

- Audit system development
- Ensure properly managed and controlled
- Ensure user involvement
- Ensure procedures and standards are in use

Data security controls

- Prevent un authorised access, change or destruction
- When data is in use or being stored
- Physical access to terminals
- Password protection
- Data level access controls

Application Controls:

● Input controls

- Data is accurate and consistent on entry
- Direct keying of data, double entry or automated input
- Data conversion, editing and error handling
- Field validation on entry
- Input authorisation and auditing
- Checks on totals to catch errors

Processing controls

- Data is accurate and complete on processing
- Checks on totals to catch errors
- Compare to master records to catch errors

- Field validation on update

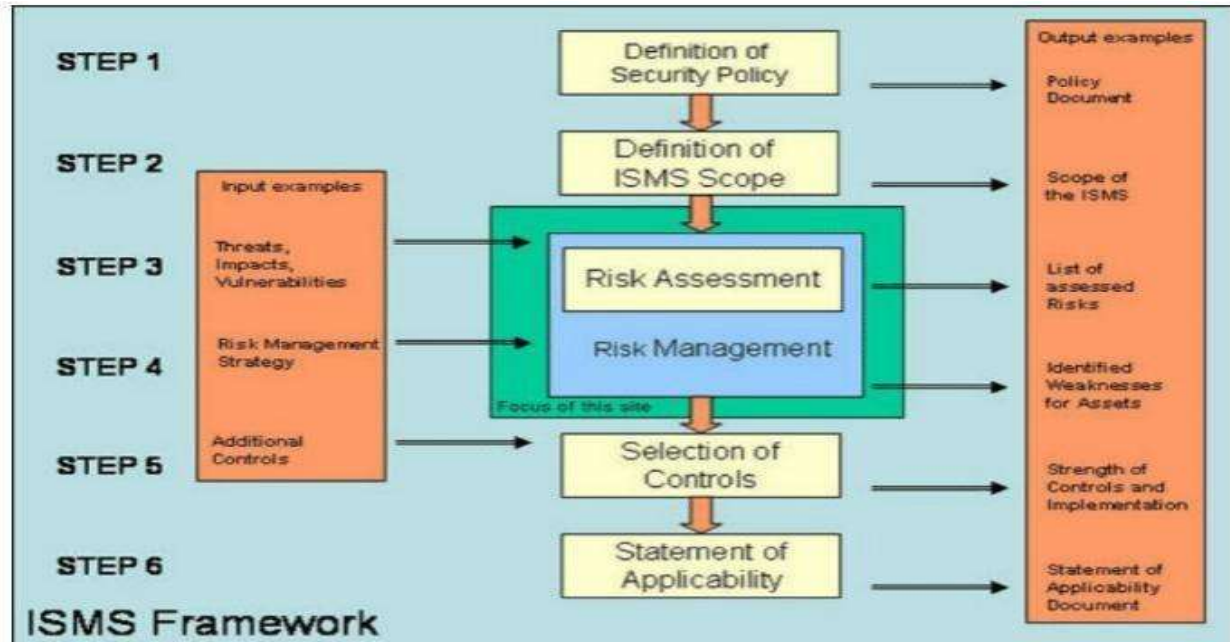
Output controls

- Data is accurate, complete and properly distributed on output
- Checks on totals to catch errors
- Review processing logs
- Track recipients of data

ISMS [Information Security Management System]

- An information security management system (ISMS) is a set of policies concerned with information security management or IT related risks.
- Steps to Develop ISMS:
- In establishing an ISMS, the scope of the ISMS is determined (STEP 1), and an information security policy is defined (STEP 2). On the basis of this security policy, a systematic approach to risk assessment is defined (STEP 3), and risks to the information assets that must be protected are identified (STEP 4).
- Risk assessment is then carried out (STEP 5).
- If, as a result of the risk assessment, unacceptable risks are found, possible ways to treat the risks should be identified and examined (STEP 6).
- Based on the risk treatment, controls to be implemented are selected (STEP 7).
- Steps 3 and 4, the Risk Assessment and Management process, comprise the heart of the ISMS and are the processes that —transform on one hand the rules and guidelines of security policy and the targets; and on the other to transform objectives of ISMS into specific plans for the implementation of controls and mechanisms that aim at minimizing threats and vulnerabilities.
- The processes and activities related to the steps 5 and 6 do not concern information risks.
- They are rather related to the operative actions required for the technical implementation, maintenance and control of security measurements.
- Appropriate controls may either be derived from existing sets of controls or mechanisms, usually included in information security standards (e.g. [ISO 17799]) and guidelines, or be the outcome of a combination or adaptation of proposed controls to the specific organizational requirements or operational characteristics.

- In both cases, step 6 is the documented mapping of the identified risks, applied to the specific organization with the technical implementation of security mechanisms the organization has decided to deploy.



The structure of an IS audit and Audit Reports

Information Security Audit

- A measure of how confidentiality , integrity and availability of an organizations information is protected and assured
- A systematic measurable technical assessment of how the organizations security policy is employed at specific site
- A part of on-going process of defining and maintaining effective security policies
- Many audit may involve everyone who uses computer resources in the organization

Why is Information System Security Important?

- Besides many direct and indirect benefits, there are also many direct and indirect risks relating to the “information systems”. These risks have led to a gap between the “need to protect systems and the degree of protection applied”.
- This GAP is caused by:
 - Widespread use of technology
 - Unevenness of technological changes
 - Interconnectivity of systems (e.g. Internet)
 - Elimination of distance, time, and space as constraints
 - External factors such as legislative, legal, and regulatory requirements or technological developments

THREATS TO INFORMATION SYSTEM

- May arise from intentional or unintentional acts and may come from internal or external sources.
- The threats may originate from, among others:
 - Natural disasters (fires, floods)
 - Environmental conditions (electrical surges)
 - Technical conditions (program bugs, disk crashes)
 - Human factors (lack of training, errors, and omissions)
 - Unauthorized access (hacking)
 - Viruses

- Other threats, such as business dependencies (reliance on 3rd party, outsourced operations, etc.)
- What Is Information

What Is Information System Security?

- Security relates to the protection of valuable assets against loss, disclosure, or damage.
- **Safeguards include-**
 - Physical safeguards for securing valuable assets from threats, sabotage, or natural disaster. E.g. locks, perimeter fences, and insurance are common
 - Logical and Technical safeguards. E.g. user identifiers, passwords, firewalls
 - Concept of security applies to all information.

Security Objective

- The objective of information system security is “the protection of the interests of those relying on information, and the information systems and communications that deliver the information, from harm resulting from failures of confidentiality, availability, and integrity (CIA)”.
- For any organization, the security objective is met when:
 - **Confidentiality:** Data / information are disclosed only to those who have a right to know it
 - **Integrity:** Data and information are protected against unauthorised modification
 - **Availability:** Information systems are available and usable when required

What information is sensitive?

- **Business Operations:** They consist of an organization’s process and procedures, most of which are deemed to be proprietary. As such, they may provide a market advantage to the organization.
- E.g. A company's client lists and the prices charged for various products and services can be damaging in the hands of a competitor.
- Most organizations prohibit the sharing of such data. However, carelessness such as inadvertent storage of data on unauthorized systems, unprotected laptops/media results in compromise.

What information is sensitive?

- **Strategic Plans:** Most organizations acknowledge that strategic plans are crucial to the success of a company.
- But do most companies really make an effort to protect these plans?
- E.g. A competitor learns that a company is testing a new product line in a specific geographic location. The competitor removes its product from that location, creating an illusory demand

for the new product. Based on the positive but false marketing results, the company decides to roll the product out nationwide. It discovers that competition for its new product is intense. Result: multi-million dollar loss as sales falter.

- Above example illustrates that keeping strategic plans confidential is essential

Protecting Computer-Held Information Systems

- “how to protect the information systems”,
 - **Rule 1:** Know what the information systems are and where these are located.
 - **Rule 2:** Know the value of the information held and how difficult it would be to recreate if it were damaged or lost.
 - **Rule 3:** Know who is authorized to access the information and what they are permitted to do with the information.
 - **Rule 4:** Know how quickly information needs to be made available should it become unavailable for whatever reason (loss, unauthorized modification, etc.)

Protection that an organization can use

- Preventative Information Protection: It is based on use of security controls.

Information system security controls are generally grouped into three types of control:

- **Physical:** Doors, Locks, Guards, Floppy Disk Access Locks, Cables locking systems to desks/walls, CCTV, Paper Shredders, Fire Suppression Systems
- **Logical (Technical):** Passwords, File Permissions, Access Control Lists, Account Privileges, Power Protection Systems
- **Administrative:** Security Awareness, User Account Revocation, Policy
- **Restorative Information Protection:** Security events that damage information systems will happen. If an organization cannot recover or recreate critical information systems in an acceptable time period, the organization will suffer and possibly have to go out of business.
- Planning & operating an effective & timely information system backup and recovery program is vital.
- Few questions any restorative information system protection program must address:
 - Has the recovery process been tested recently?
 - How long did it take?
 - How much productivity was lost?

- Did everything go according to plan?
- **Holistic Protection:** Protection of corporate information systems from harm or loss must be done holistically (-global/macro level-) and give the organization the appropriate level of security
- One must plan for the unexpected and unknown, expect the worst events to happen, and recover from these events if and when they occur. Such events can't be planned, and they tend to happen at the most inopportune times. It is inappropriate to wait until the last minute to decide on a protection plan and recovery process at a cost that is acceptable to the business

Information Security Policy

- A Policy is a plan or course of action, designed to influence and determine decisions, actions and other matters.
- A security policy is a set of laws, rules, and practices that regulates how assets including sensitive information are managed, protected, and distributed
- An information Security policy addresses many issues such as CIA concerns, access rights and related procedures, separation of duties, controls, ownership and authority issues

Information System Policy?

- **User Security Policy:** sets out the responsibilities and requirements for all IT system users.
- It provides security terms of reference for Users, Line Managers and System Owners.
- **Acceptable Usage Policy:** sets out terms for acceptable use of email and Internet services.
- **Organizational Information Security Policy:** sets out the Group policy for the security of its information assets and the Information Technology (IT) systems processing this information. It is THE MAIN IT security policy document.
- **Network & System Security Policy:** sets out detailed policy for system and network security and applies to IT department users
- **Information Classification Policy:** sets out the policy for the classification of information
- **Conditions of Connection:** sets out the Group policy for connecting to their network. It applies to all organizations connecting to the Group, and relates to the conditions that apply to different suppliers' systems.

Security Organisation Structure

Information Security Forum (ISF): Forum includes GSO, AGSO(Ass. Group Security Officer), and senior representatives from every division.

- **Role-** to ensure that there is clear direction and visible management support of security initiatives within the organisation.

- **Information Security Management Group (ISMG):** This cross functional group includes AGSO, Divisional System Security Officer (DSSO) from every division, IT Security Officer (ITSO), and the Personnel and Facilities Management Security Officers
- **Role-** to co-ordinate the implementation and management of information security controls across all of the divisions and sites

Group Security Officer (GSO):

- **Role-** overall responsibility for security within the Group. This includes the security of all information assets, the network accreditation scheme & for non-IT security including physical & personnel matters.
- **Assistant Group Security Officer (AGSO):** Reports to GSO, ISF.
- **Role-** to co-ordinate the implementation and management of information security across the Group

IT Management:

- **Role-** overall responsibility for security of the IT infrastructure.
- **IT Security Officer (ITSO):** Reports to the ISMG on IT security matters.
- **Role-** to manage IT security Programmes and IT security incidents.
- **Facilities Management Security Officer (FMSO):** Reports directly to Facilities Management on all
 - security matters relating to personnel.
- **Role-** to ensure that the controls are implemented, adhered to and reviewed as necessary.
- **Installation Security Officer (ISO):** ISO appointed for each IT environment.
- **Role-** responsible for all security matters related to their system/installation and/or network and will
 - **System Security Officer (SSO):** SSO appointed for major application system(s)
 - **Role-** to focus on business aspects of security thus ensuring that the information security of the system meets all relevant business control objectives.
 - **Divisional System Security Officer (DSSO):** A System Security Officer (SSO) from each division will be appointed as a DSSO.
 - **Role-** Same as a SSO; to represent the SSOs in their division at the ISMG and communicate requirements and issues to/from this group.

- **Personnel Security Officer (PSO):** Reports directly to Personnel Management and the ISMG on all security matters relating to personnel.
- **System Owners:** Role- overall responsibility for the information security of their own systems.
 - Responsible for allocation of protective markings to their systems and data according to the Information Classification policy. Delegating day-to-day operational aspects of live systems.
 - **Line Managers:** Role- to ensure compliance with the aims and objectives of the policy. To ensure that all required security measures are understood and in force
 - **Users:** Role- to comply with the security procedures for their system and any applicable general IT security guidance.

Audit Policy

○ PURPOSE of the IS Audit policy

- To provide guidelines to the audit team to conduct an audit on IT based infrastructure system.
- The Audit is done to protect entire system from the most common security threats which includes the following
 - Access to confidential data
 - Unauthorized access of the department computers.
 - Password disclosure compromise
 - Virus infections
 - Denial of service (DoS) attacks
 - Open ports, which may be accessed by outsiders
 - Unrestricted modems-unnecessarily open ports

IS Audit Reports

- **Structure:** The components of an audit report are discussed below:
- **Cover and Title Page:** Audit reports should use a standard cover, with a window showing the title, the department's name, report's date of issue, and names of the audit team members. Some of these items may be repeated at the bottom of each page.
- **Table of Contents:** The table lists the sections and subsections with page numbers including summary and recommendations, introduction, findings (by audit field) and appendices (as required).

- **Summary / Executive Summary:** It gives a quick overview of the salient features- main issues covered, recommendations. It should not normally exceed 3 pages

- **Introduction:**

It should not repeat Summary details. It should include the following elements

Context: It briefly describes conditions in the audit entity during the period under review E.g. the entity's role, size and organisation especially with regard to information system management, significant pressures on information system management during the period under review, events that need to be noted, organisational changes, IT disruptions, changes in roles and programs, results of internal audits or follow-up to our previous audits, if applicable.

- **Purpose:** It is a short description of what functions and special programs were audited and the clients' authorities
- **Scope:** It lists the period under review, the issues covered in each function and program, the locations visited and the on-site dates
- **Methodology:** It briefly describes sampling, data collection techniques. basis for auditors' opinions, any weaknesses in the methodology
- **Findings:** It constitutes the main part of an audit report. Results of examination of audit issues in the context of established objectives and clients' expectations.
- **Opinion:** If the audit assignment requires the auditor to express an audit opinion, the auditor shall do so as per the requirement.
- **Appendices:** Appendices helps in understanding the report. They usually include comprehensive statistics, quotes from publications, documents, and references.
- **Level of Detail:** The depth of coverage for issues should normally reflect the significance of the findings. Situations representing a high degree of risk or indicating shortcomings that are serious enough to justify a recommendation should be treated extensively.
- Specific initiatives should be described in detail, while issues which are general in nature or where the department meets the expectations should be dealt with briefly.
- **Commentary:** Where a “recommendation and a compliment” are made under the same issue, they should be in separate paragraphs; otherwise, they may confuse the reader and reduce the impact of one or the other.
- Statistics need to be used consistently throughout the report. Sample size and error rate mean more when they are given in context.
- The size of the population, the number of transactions and the period of time provide that context.
- Percentages should not be used when referring to small samples (<100)

